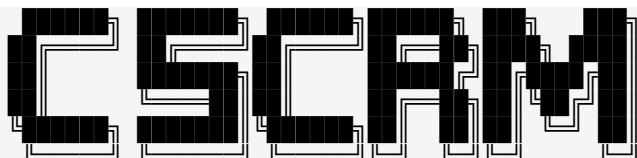


README — Kit GQM+PRAGMATIC para Indicadores CSCRМ España 2026

Guía de inicio rápido, inventario y arquitectura del sistema de indicadores

Versión 1.0 · Documento (g) del Kit GQM+PRAGMATIC CSCRМ



GQM + PRAGMATIC · INDICADORES CSCRМ ESPAÑA 2026

¿Qué es este kit?

El **Kit GQM+PRAGMATIC para Indicadores CSCRМ España 2026** implementa, por primera vez en el contexto español, la doble metodología **GQM** (Basili & Rombach 1988 / SEI CMU) + **PRAGMATIC** (Brotby & Hinson 2013, CRC Press) aplicada a los 20 indicadores de Gestión de Riesgos de Ciberseguridad en la Cadena de Suministro.

Qué lo diferencia de un simple listado de KPIs:

- Cada indicador está **derivado formalmente** desde uno de los 4 objetivos nacionales CSCRМ mediante el árbol GQM
- Cada indicador ha sido **calificado en los 9 criterios PRAGMATIC** (escala 0-81) con análisis individual
- El sistema identifica el **Conjunto Mínimo Viable** de 8 indicadores para organizaciones con recursos limitados
- Todo está **trazado a requisitos normativos** (ENS, NIS2, NIST SP 800-161r1, ISO 27001:2022, CRA, NIST FIPS 203/204/205)

Inventario del Kit — 7 Documentos

Archivo	Documento	Contenido
a-GQM-encuesta-integral.md	(a) Encuesta Integral CSCR	60+ preguntas estructuradas en 10 secciones · escala Likert + opciones múltiples
b-GQM-matriz-pragmatic.md	(b) Matriz PRAGMATIC	Tabla 20×9 criterios · puntuación individual · ranking · análisis detallado
c-GQM-narrativa-explicativa.md	(c) Narrativa Explicativa	Fundamento epistemológico · hallazgos principales · paradoja de la oportunidad
d-GQM-mapeo-normativo.md	(d) Mapeo Normativo	20 indicadores × 8 marcos normativos · tabla de trazabilidad completa
e-GQM-plantilla-excel.md	(e) Plantilla Excel	10 hojas funcionales: IGM, PRAGMATIC scorecard, ROI, hoja de ruta, dashboard
f-GQM-reporte-ejecutivo.md	(f) Reporte Ejecutivo PPT	18 diapositivas con notas · ROI por indicador · plan de acción priorizado
g-README-GQM-PRAGMATIC.md	(g) Este README	Guía de inicio · arquitectura · ontología · FAQ · changelog

Inicio Rápido por Perfil

Para el CISO / Responsable de Ciberseguridad:

- 1 → Leer documento (a): comprender la encuesta y sus 10 secciones
- 2 → Revisar documento (b): identificar los 8 indicadores del CMV
- 3 → Revisar documento (d): identificar qué indicadores son legalmente exigibles (✓)
- 4 → Implementar documento (e) en Excel:
 - Hoja DATOS_MEDICION: introducir valores actuales
 - IGM, benchmark y hoja de ruta se generan automáticamente
- 5 → Adaptar documento (f) con los valores calculados
- 6 → Presentar al Consejo usando diapositivas 6, 13 y 16 como núcleo

Para el Equipo de Investigación / Academia:

- 1 → Leer documento (c): fundamento epistemológico del marco GQM+PRAGMATIC
- 2 → Revisar documento (b): análisis detallado con justificaciones por indicador
- 3 → Usar valores de referencia del documento (e) como baseline para hipótesis
- 4 → El documento (d) proporciona el marco regulatorio para análisis de cumplimiento

Para el Regulador / Supervisor:

- Ver los 5 indicadores verificables externamente (diapositiva 15 del documento f)
- M14, M18, M20: verificables por auditoría documental
- El documento (d) identifica la base legal de cada indicador con artículo específico

Para la Alta Dirección / Consejo:

- Documento (c), sección I: "El Problema de las Métricas Vacías" (10 min)
- Documento (f), diapositivas 2, 7 y 16
- Una sola pregunta calibradora: "¿Cuántos de estos 8 indicadores medíamos antes de hoy?"

Arquitectura del Sistema

Árbol de Trazabilidad Completo

ESTRATEGIA NACIONAL

- Estrategia Nacional de Ciberseguridad (en revisión 2026)
- Plan de Choque INCIBE 2025 (1.157 M€)
- Anteproyecto Ley Coordinación y Gobernanza Ciberseguridad (ene. 2025)
- NIS2 UE 2022/2555



OBJETIVOS GQM (4 objetivos)

- 01: Reducir incidentes CS con origen en cadena de suministro → M01-M04
- 02: Madurez CSCRM $\geq$ L3 en organizaciones esenciales → M05-M09, M17-M18, M20
- 03: Visibilidad n-tier en infraestructuras críticas → M10-M12, M17, M19-M20
- 04: Respuesta coordinada nacional a incidentes CS → M13-M16



INDICADORES (20) con puntuación PRAGMATIC

- GRUPO A – Impacto (M01-M04): MTTD: 66✓ | Tasa: 63⚠ | Coste: 57⚠
- GRUPO B – Madurez (M05-M09): Brecha dom: 75✓ | IGM: 69✓ | D.Diligence: 69✓
- GRUPO C – Visibilidad (M10-M12): SBOM: 72✓ | N-tier: 60⚠ | PQC: 63⚠
- GRUPO D – Respuesta (M13-M16): Plazos NIS2: 75✓ | PRI: 69✓ | Ejercicios: 69✓
- GRUPO E – Emergentes (M17-M20): Ciclo Vida: 78✓ | Contratos: 75✓ | ZT: 66✓

Los 9 Criterios PRAGMATIC: Definición de Referencia

Criterio	Letra	Pregunta clave	Escala
Predictivo	P	¿Alerta con antelación suficiente para actuar?	0/3/6/9
Relevante	R	¿Quién decide algo basándose en esta métrica?	0/3/6/9
Accionable	A	¿Qué se hace diferente cuando sube o baja?	0/3/6/9
Genuino	G	¿Puede mejorarse sin mejorar el comportamiento real?	0/3/6/9
Significativo	M	¿Lo entiende el CEO sin traducción técnica?	0/3/6/9
Preciso	Ac	¿La fuente de datos es consistente y reproducible?	0/3/6/9
Oportuno	T	¿Llega antes de que la decisión sea irreversible?	0/3/6/9
Independiente	I	¿Puede ser verificado por alguien sin conflicto de interés?	0/3/6/9
Rentable	C	¿Vale más que lo que cuesta producirla?	0/3/6/9

Fuente: Brotby, K. & Hinson, G. (2013). *PRAGMATIC Security Metrics*. CRC Press. ISBN 9781439881538.

Conjunto Mínimo Viable (CMV)

#	ID	Indicador	PRAGMATIC	Objetivo	Norma crítica
1	M20	Ciclo de Vida del Proveedor	78	O2+O3	NIST SP 800-161r1
2	M09	Índice de Brecha por Dominio	75	O2	IMC INCIBE-CERT
3	M14	Cumplimiento Plazos NIS2	75	O4	NIS2 Art. 23
4	M18	Cláusulas Contractuales CS	75	O2	NIS2 Art. 21.4
5	M11	Cobertura SBOM	72	O3	CRA Art. 13
6	M07	Distribución IGM	69	O2	NIST SP 800-55v2
7	M02	MTTD-SC	66	O1	NIST CSF DE.AE-04
8	M13	PRI con módulo CS	69	O4	NIS2 Art. 21.2.a

Marco Normativo de Referencia Completo

Marco	Versión	Cobertura en el Kit
NIST SP 800-161r1	Nov. 2024	C-SCRM Tasks C-GV.SC-1 a C-GV.SC-10
NIST CSF 2.0	Feb. 2024	GV.SC, DE.AE, RS.CO, PR.AA, PR.DS
NIST SP 800-55v2	Dic. 2024	Marco de medición de métricas de seguridad
NIST SP 800-207	2020	Zero Trust Architecture (M17)
NIST FIPS 203/204/205	Ago. 2024	ML-KEM, ML-DSA, SLH-DSA (M12)
ENS RD 311/2022	May. 2022	op.ext, op.acc, op.mon, org
NIS2 UE 2022/2555	Oct. 2022	Art. 21, 22, 23, 29
Anteproyecto Ley Ciberseguridad España	Ene. 2025	Transposición NIS2 + requisitos adicionales
ISO/IEC 27001:2022	Oct. 2022	Cláusulas 5.19-5.23, 8.4, 8.8, 9.1
CRA (UE 2024/2847)	Oct. 2024	SBOM; productos con elementos digitales
DORA UE 2022/2554	En vigor ene. 2025	Sector financiero; TLPT; registro ICT
INCIBE-CERT IMC v2.8	Feb. 2023	46 métricas de ciberresiliencia; escala L0-L5
FAIR Institute	2025	Cuantificación de riesgo; factores de reducción ALE
ENISA NIS Investments	Dic. 2025	Benchmarks europeos de implementación NIS2
Cipher/Prosegur Supply Chain Report	Feb. 2026	MTTD 254d; coste 4,33 M€

Preguntas Frecuentes

¿Cuál es la diferencia entre la Encuesta CSCRm (documento a) y el kit GQM+PRAGMATIC?

La encuesta define *qué preguntar* para medir la madurez. El kit GQM+PRAGMATIC define *qué indicadores usar, por qué son válidos, y cómo saber que miden lo que dicen medir*. Son complementarios: la encuesta genera los datos; el framework los convierte en indicadores de calidad verificada.

¿Es necesario evaluar los 20 indicadores o puedo empezar con los 8 del CMV?

El CMV está diseñado exactamente para este caso. Los 8 indicadores cubren los 4 objetivos GQM nacionales y tienen PRAGMATIC ≥ 65 . Es un punto de partida sólido.

¿La evaluación PRAGMATIC es fija o puede ajustarse?

Los valores de la Matriz PRAGMATIC son una propuesta fundamentada, no una tabla de piedra. Cada organización puede ajustar las puntuaciones según su contexto operativo.

¿Con qué frecuencia debe evaluarse el marco completo?

Ciclo recomendado: anual para el diagnóstico completo, semestral para los 8 indicadores del CMV.
Revisar también tras cada incidente significativo.

Registro de Cambios

Versión	Fecha	Cambios
1.0	Abr. 2026	Versión inicial: 20 indicadores, 4 objetivos GQM, matriz PRAGMATIC completa
1.1 (prevista)	Oct. 2026	Actualización benchmarks ENISA NIS Investments 2026
1.2 (prevista)	Ene. 2027	Indicadores post-aprobación Ley Coordinación y Gobernanza
2.0 (prevista)	2028	Revisión completa post-primeras evaluaciones NIS2 + datos CRA

Licencia y Atribución

Distribuido bajo **Creative Commons BY-NC-SA 4.0**

Atribución recomendada:

Kit GQM+PRAGMATIC para Indicadores CSCRM España 2026, v1.0. Basado en: Basili & Rombach (1988) GQM · Brotby & Hinson (2013) PRAGMATIC Security Metrics (CRC Press) · NIST SP 800-55v2 dic. 2024 · NIST SP 800-161r1 nov. 2024 · INCIBE-CERT IMC v2.8 · ENS RD 311/2022 · NIS2 UE 2022/2555.

"Una métrica que no predice, no actúa y no puede ser verificada es un número con ambiciones narrativas. El marco GQM+PRAGMATIC separa lo primero de lo segundo."

© 2026 · README Kit GQM+PRAGMATIC CSCRM España · Documento (g) · Versión 1.0 · Abril 2026